

12

The Enforcement Gap

Entra solves identity. You build the rest.

Three attack vectors



Jailbreak

Adversarial prompts override system instructions



Token theft

Agent leaks or misuses OAuth tokens



Prompt injection

External data poisons agent reasoning

What Entra Agent ID provides



Agent identities

Blueprints for creating agent IDs with parent-child relationships. Works across Microsoft and non-Microsoft platforms.

GA APR 2026



Conditional Access

Adaptive access policies for agents. Risk-based auth, geo-fencing, device compliance checks.

GA APR 2026



Protocol support

OAuth 2.0, MCP, and A2A for authentication and agent-to-agent communication.

GA APR 2026

What Entra does NOT provide



Jailbreak prevention

No built-in guardrails to stop adversarial prompts from overriding instructions.

NOT INCLUDED



Tool permissions

No deterministic boundaries for which tools an agent can call or what data it can access.

NOT INCLUDED



Agent-specific DLP

No reactive scanning for sensitive data in agent prompts or outputs.

NOT INCLUDED

The identity layer

✗ WITHOUT ENTRA

Service principal

Agent uses generic app identity. No lifecycle management, no conditional access, no governance.

```
# same service principal for all agents
client_id = os.getenv('APP_CLIENT_ID') # no
way to revoke per-agent
```

✓ WITH ENTRA AGENT ID

Agent identity

Each agent gets its own identity. Conditional access, audit logs, lifecycle management built-in.

```
# unique identity per agent agent_id =
entra.create_agent_identity(
    blueprint='customer_support_agent' )
```

What you build yourself



Deterministic shell

Code-enforced boundaries, not prompt-based



Tool validation

Allowlists, scope checks before execution



Observability

Log everything, detect anomalies, kill fast

Tool restriction pattern

tool_executor.py

```
class ToolExecutor:
    ALLOWED_TOOLS = {
        'read_calendar': ['Calendar.Read'],
        'send_email': ['Mail.Send'],
    }

    def execute(self, tool, token):
        if tool not in self.ALLOWED_TOOLS:
            raise Forbidden()
        for scope in self.ALLOWED_TOOLS[tool]:
            if scope not in token.scopes:
                raise Forbidden()
```



What actually works

Identity is solvable — Microsoft shipped it in April 2026. Enforcement is not. My take: Entra gives you the identity layer for free. The deterministic shell, tool validation, and observability? You write those. If it matters, don't trust the prompt.

Three-layer defense



Identity

Blueprints, conditional access, audit logs



Enforcement

Deterministic shell, tool validation



Observability

Log everything, detect anomalies, kill fast

Apr 2026

Agent identities went GA